

CYBER THREAT INTELLIGENCE REPORT
CTI-2026-0524-IPKVM-BMC

IP-KVM / BMC 계층을 표적으로 한 북한 연계 위협 행위자의 3대 공격 시나리오

가상자산 거래소 · DeFi 인프라 대상 공급망 · 사회공학 융합 위협 분석

문서 ID	CTI-2026-0524-IPKVM-BMC
분류 / TLP	TLP:AMBER (내부·신뢰 파트너 한정)
발행일	2026-05-24
대상 인프라	가상자산 거래소 · DeFi 운영 조직의 OOB 서버 관리 계층 (BMC/IPMI/iDRAC/iLO)
위협 행위자	Lazarus Group (HIDDEN COBRA / APT38), BlueNoroff 클러스터
프레임워크	MITRE ATT&CK Enterprise v15

목차

1. 개요 (Executive Summary)	3
2. 위협 행위자 프로파일	3
3. 공격 시나리오	4
3.1 시나리오 1 — 가짜 채용·벤더 사칭을 통한 BMC 관리 콘솔 침투	4
3.2 시나리오 2 — BMC 펌웨어 공급망 오염	5
3.3 시나리오 3 — 인터넷 노출 IPMI를 통한 KVM 하이재킹 및 측면 이동	6
4. 통합 위협 서사 및 영향	7
5. MITRE ATT&CK Navigator 매핑	7
6. 탐지 지표(IOC) 및 탐지 룰	8
6.1 행위 기반 탐지 지표 (Behavioral IOC)	8
6.2 Sigma 탐지 룰 (예시)	8
7. 탐지 및 완화 권고	9
8. 참고 출처	10

1. 개요 (Executive Summary)

본 보고서는 가상자산 거래소 및 DeFi 인프라 운영 조직을 1차 표적으로 가정하고, 서버 관리 계층인 **IP-KVM / KVM-over-IP (BMC-IPMI-iDRAC-iLO)** 를 침투 및 지속성 확보의 핵심 거점으로 삼는 세 가지 공격 시나리오를 분석한다.

OOB(Out-of-Band) 관리 계층은 “관리자가 가장 신뢰하지만 가장 적게 모니터링하는 계층”이라는 구조적 사각지대를 갖는다. BMC는 메인 OS와 독립된 별도 Linux 스택과 자체 네트워크 스택을 운용하므로, 호스트 OS의 재설치 또는 교체로도 제거되지 않는 지속성을 공격자에게 제공한다. 실제 사례인 iLOBleed 임플란트는 펌웨어 내부에 은닉되어 OS 재설치 후에도 생존하였으며, 서버에 대한 사실상 전능한 제어와 반복적 디스크 파괴를 수행한 것으로 보고되었다.

북한 연계 행위자(Lazarus 및 하위 클러스터)는 이 계층을 표적할 동기와 역량을 모두 갖추고 있다. 2026년 들어 이들은 글로벌 금융·국방·기술 부문을 지속 표적하면서 클라우드 인프라, 개발자 환경, 소프트웨어 공급망으로 초점을 확대하였고, 2024년 10월 이래 AI 기반 기법을 통합하여 작전의 정교함과 효율성을 크게 끌어올린 것으로 평가된다. 특히 가상자산 부문에서는 2025년 2월 Bybit에서 약 15억 달러를 탈취한 뒤 자산을 수천 개 주소로 분산하였고, 2026년 4월에는 약 2억 9,200만 달러 규모의 KelpDAO 브리지 익스플로잇이 동 그룹과 연계되는 등, 스마트 컨트랙트 자체가 아니라 그 주변 인프라를 표적하는 방향으로 전환하고 있다.

핵심 판단 (Key Judgements)

KJ-1	BMC/IPMI 계층은 OS와 독립적이어서 OS 재설치로 제거 불가능한 지속성을 제공하며, 거래소의 핫월렛·서명 인프라에 대한 “관문”으로 기능한다.
KJ-2	Lazarus의 검증된 진입 기법(가짜 채용·오픈소스 공급망 오염)과 BMC 사각지대가 결합될 경우, 탐지 없이 장기 체류가 가능하다.
KJ-3	인터넷 노출 IPMI를 통한 KVM 하이재킹은 가설이 아닌 전례(JungleSec, 2018)가 있으며, 북한 식 변주는 단순 암호화가 아닌 자산 탈취·첩보로 귀결된다.

2. 위협 행위자 프로파일

항목	내용
주체	Lazarus Group (HIDDEN COBRA / APT38), 하위 클러스터 BlueNoroff 등
동기	가상자산 탈취(체제 자금 조달), 첩보, 장기 지속성 확보
핵심 TTP	가짜 채용·벤더 사칭, 오픈소스 생태계 공급망 오염, 펌웨어 임플란트, OOB 인터페이스 악용
최근 진화	AI 기반 미끼 콘텐츠 생성, 인프라(브리지·검증자·관리 계층) 직접 표적화

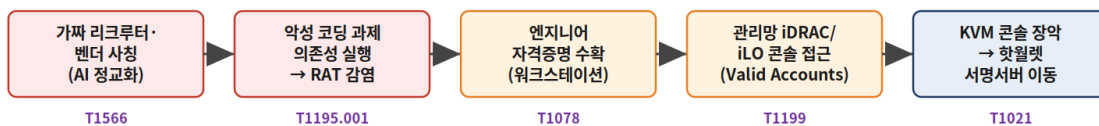
Lazarus의 모듈형·적응형 운영 방식은 이미 검증되었다. 공개 보고에 따르면, 이들이 운용한 다수의 C2 서버는 React 애플리케이션과 Node.js API로 구축된 웹 기반 관리 플랫폼을 공통으로 호스팅하였으며, 페이로드와 난독화 기법을 변경하면서도 이 관리 계층은 일관되게 유지하여 탈취 데이터 조직화·피해 호스트 감독·페이로드 전달을 총괄하는 허브로 활용하였다. 이러한 “운영 표준화” 특성은 본 보고서의 세 시나리오가 단발성이 아니라 캠페인 단위로 반복 운용될 수 있음을 시사한다.

3. 공격 시나리오

3.1 시나리오 1 — 가짜 채용·벤더 사칭을 통한 BMC 관리 콘솔 침투

진입 유형: **사회공학 (Social Engineering Entry)**

시나리오 1 · 사회공학 진입 → BMC 콘솔 침투



개요

Lazarus의 시그니처 진입 기법인 가짜 리크루터·벤더 사칭을 활용하여 거래소의 인프라 엔지니어·DevOps·SRE를 표적한다. 미끼는 “서버 관리 자동화 과제”, “BMC 펌웨어 호환성 테스트 툴”, “Redfish API 연동 코딩 과제” 등으로 위장된 악성 의존성이다.

근거가 되는 실제 TTP

Lazarus는 npm·PyPI·GitHub 등 신뢰받는 개발자 생태계를 통해 코딩 과제에 내장된 의존성 형태로 RAT를 유포하며, 가상자산·블록체인 개발자에 특히 집중하는 고도로 적응적·모듈형·지속적 캠페인을 운영해 왔다. 또한 “ClickFix” 사회공학 기법과 GolangGhost 백도어를 동원하여, 피해자가 실제 채용 절차에 있다고 믿게 만든 뒤 자격증명을 탈취하고 가상자산을 빼돌린 사례가 확인되었다.

공격 흐름

1. AI로 정교화한 가짜 리크루터 프로필·기업 페이지로 표적 엔지니어 접촉
2. 코딩 과제·툴에 내장된 악성 의존성 실행 → 엔지니어 워크스테이션 RAT 감염, 자격증명 수확
3. 탈취한 관리자 자격증명으로 내부 관리망의 iDRAC/iLO/BMC 웹 콘솔 접근
4. KVM-over-IP 콘솔로 호스트 입출력 잠락 및 가상 미디어 마운트로 공격자 이미지 부팅
5. 핫월렛 서명 서버·키 관리 호스트로 측면 이동

3.2 시나리오 2 — BMC 펌웨어 공급망 오염

진입 유형: 펌웨어 공급망 + OS 무관 지속성 (Firmware Supply Chain)

시나리오 2 · BMC 펌웨어 공급망 오염 → OS 무관 지속성



개요

서버 도입 단계 또는 펌웨어 업데이트 경로를 오염시켜, OS 재설치로도 제거되지 않는 펌웨어 임플란트를 심는다. 거래소처럼 동질적(homogeneous) 서버 환경에서는 단일 오염 펌웨어가 전체 랙으로 확산될 수 있어 영향이 증폭된다.

근거가 되는 실제 TTP

BMC 펌웨어 신뢰사슬은 지속적으로 흔들리고 있다. Supermicro는 2026년 1월에도 BMC 펌웨어 취약점 (CVE-2025-12006, CVE-2025-12007 포함)에 대한 업데이트를 배포하였으며, 일부 플랫폼은 수정 적용 전 별도의 transition firmware가 필요할 정도로 업데이트 경로 자체가 복잡하여 누락·지연이 빈번하다. 지속성 측면에서 iLOBleed 사례는 하드웨어 루트 오브 트러스트를 갖춘 신형 시스템조차 펌웨어 다운그레이드에 취약하면 영향받을 수 있음을 보였고, 2020년 이래 야생에서 은밀·지속·파괴적으로 관찰되었다.

공격 흐름

1. 서버 벤더·리셀러 또는 펌웨어 배포 채널 침해 (또는 시나리오 1 로 확보한 관리망 접근 활용)
2. 무결성 검증이 미흡한 BMC 에 변조 펌웨어 또는 다운그레이드 이미지 삽입
3. 펌웨어 내부 임플란트로 KVM 세션 미러링·자격증명 가로채기·은닉 C2 채널 구축
4. OS 재설치·서버 복구 후에도 지속, 필요 시 디스크 파괴/PDoS 로 전환

3.3 시나리오 3 — 인터넷 노출 IPMI 를 통한 KVM 하이재킹 및 측면 이동

진입 유형: 외부 노출 악용 (External Exposure)

시나리오 3 · 노출 IPMI KVM 하이재킹 → 측면 이동 → 자산 탈취



개요

Shodan·Censys로 인터넷에 노출된 BMC를 스캔하고, 기본 크리덴셜·IPMI 인증 우회로 진입하여 KVM 기능으로 호스트를 장악한 뒤 내부로 측면 이동한다.

근거가 되는 실제 TTP

이는 가설이 아니라 명백한 전례가 있다. 2018년 JungleSec 랜섬웨어 공격에서 공격자들은 인터넷에 노출된 IPMI 인터페이스에 기본 패스워드로 접근한 뒤, KVM 기능으로 호스트 OS에 진입하여 데이터를 암호화하고 내부망의 도달 가능한 다른 시스템으로 측면 이동하였다. 단일 포트 장악만으로도 피해가 치명적인데, 공격자가 단일 iDRAC/iLO 포트를 확보하면 호스트를 강제 종료하여 수십 대의 VM을 즉시 다운시키거나, BMC에 악성 펌웨어를 플래시하여 서버를 영구 무력화(PDoS)할 수 있고, 대부분의 BMC가 자체 네트워크 스택을 가진 축소형 Linux를 구동하므로 다른 인프라를 공격하는 교두보로 기능한다.

복합적 변주

단순 암호화·금전 요구에 그치지 않고, 장악한 KVM 세션을 통해 거래소의 핫월렛 서명 절차·내부 운영 콘솔을 관찰·조작하여 자금 탈취로 직결시키며, 동시에 장기 첩보용 지속성을 병행한다는 점이 일반 범죄 그룹과 구별되는 특징이다.

공격 흐름

1. Shodan·Censys 로 노출 BMC·IPMI 자산 식별
2. 기본 크리덴셜, IPMI 2.0 cipher-zero, RAKP 해시 유출(오프라인 크래킹) 등으로 인증 우회
3. KVM-over-IP 콘솔로 호스트 장악, 가상 미디어로 부팅 제어
4. BMC 를 교두보로 하이퍼바이저·서명 서버·DB 로 측면 이동
5. 가상자산 탈취 후 다수 주소로 자금 분산(세탁), 펌웨어 지속성 유지

4. 통합 위협 서사 및 영향

세 시나리오에는 진입 벡터가 상이하나 동일한 종착점으로 수렴한다: OOB라서 감시받지 않는 사각지대 장악 → OS 무관 펌웨어 지속성 확보 → KVM을 통한 입출력·부팅 완전 통제 → 핫월렛·서명 인프라 도달 및 가상자산 탈취. 동질적 서버 환경을 운영하는 거래소에서는 단일 거점 장악이 사이트 전체 규모의 파국적 시나리오로 확대될 수 있다.

5. MITRE ATT&CK Navigator 매핑

아래 표는 세 시나리오에서 관찰되는 기법을 ATT&CK 전술(Tactic) 순서로 정리한 것이다. 각 셀의 ●는 해당 시나리오 적용 여부를 표시한다.

전술 (Tactic)	기법 / 하위기법	ID	S1	S2	S3
정찰	Active Scanning (노출 BMC 스캔)	T1595	.	.	●
초기 접근	Phishing (가짜 채용·사칭)	T1566	●	.	.
초기 접근	Supply Chain — Dev Tools/SW	T1195.001	●	.	.
초기 접근	Supply Chain — Hardware/Firmware	T1195.003	.	●	.
초기 접근	External Remote Services (IPMI)	T1133	.	.	●
초기 접근	Trusted Relationship (벤더)	T1199	●	.	.
실행/지속성	System Firmware (BMC 임플란트)	T1542.001	.	●	.
지속성	Modify System Image	T1601	.	●	.
자격 접근	Valid Accounts (Default)	T1078 / .001	●	.	●
방어 회피	Modify Authentication Process	T1556	.	.	●
측면 이동	Remote Services / Exploitation	T1021 / T1210	●	.	●
영향	Data Destruction (디스크/PDoS)	T1561	.	●	.
영향	Financial Theft (가상자산 탈취)	T1657	.	.	●

S1 = 시나리오1(사회공학) · S2 = 시나리오2(펌웨어 공급망) · S3 = 시나리오3(노출 IPMI)

6. 탐지 지표(IOC) 및 탐지 룰

6.1 행위 기반 탐지 지표 (Behavioral IOC)

범주	관찰 가능 지표	연관 시나리오
BMC 인증	IPMI cipher-zero 세션 수립, RAKP 인증 전 해시 응답, 단시간 다수 로그인 실패 후 성공	S3
BMC 네트워크	BMC 서브넷에서 발생하는 비정상 아웃바운드(외부 IP) 트래픽, 비표준 포트 사용	S2 · S3
펌웨어	BMC 펌웨어 버전 다운그레이드, 무결성/RoT 측정값 변경, 예정 외 펌웨어 플래시	S2
KVM 세션	근무 외 시간 가상 미디어 마운트, 비인가 호스트의 콘솔 리다이렉션 활성화	S1 · S2 · S3
엔드포인트	npm/pip 설치 직후 외부 C2 연결, 개발 도구(node/python)의 비정상 자식 프로세스	S1
자격증명	관리자 계정의 비정상 시간대·지역 iDRAC/iLO 로그인, 신규 BMC 로컬 계정 생성	S1 · S3

6.2 Sigma 탐지 룰 (예시)

(1) IPMI cipher-zero 인증 우회 시도 탐지

```

title: Suspicious IPMI Cipher Zero Authentication
id: a1f3c2d4-bmc-0001-ipmi-cipherzero
status: experimental
logsource:
  product: bmc
  service: ipmi
detection:
  sel_cipher:
    auth_cipher_suite: 0      # cipher-zero = no auth
  sel_priv:
    requested_privilege: 'ADMINISTRATOR'
  condition: sel_cipher and sel_priv
level: high
tags: [attack.initial_access, attack.t1133, attack.t1556]

```

(2) BMC 서브넷 비정상 아웃바운드 C2 탐지

```

title: Unexpected Outbound Traffic From BMC Subnet
id: a1f3c2d4-bmc-0002-egress
logsource:
  category: firewall
detection:
  sel_src:
    src_ip|cidr: '10.10.250.0/24'  # 관리 전용 BMC 대역
  sel_dst_external:
    dst_ip|cidr|not:
      - '10.0.0.0/8'

```

```

- '172.16.0.0/12'
- '192.168.0.0/16'
condition: sel_src and sel_dst_external
level: critical
tags: [attack.persistence, attack.t1542.001, attack.exfiltration]

```

(3) 개발 도구 설치 직후 C2 연결 (시나리오 1)

```

title: Dev Package Install Followed by External Connection
id: a1f3c2d4-bmc-0003-npm-c2
logsource:
  category: process_creation
detection:
  sel_install:
    Image|endswith: ['\\npm.exe', '\\pip.exe', '\\node.exe']
  sel_net:
    ParentImage|endswith: ['\\node.exe', '\\python.exe']
    DestinationIsExternal: true
  condition: sel_install and sel_net
level: high
tags: [attack.initial_access, attack.t1195.001, attack.t1566]

```

※ 위 룰의 CIDR·계정·경로는 환경별 자산 인벤토리에 맞게 조정 필요. 운영 적용 전 false-positive 튜닝 권장.

7. 탐지 및 완화 권고

영역	권고 사항
네트워크 분리	Redfish·IPMI 등 모든 원격 관리 인터페이스와 BMC 서브시스템을 전용 관리망에 배치하고 외부 노출을 차단하며, 내부 접근도 ACL·방화벽으로 관리자에 한정한다.
기본 계정·펌웨어	펌웨어의 벤더 기본 설정을 검토하여 내장 관리자 계정을 비활성화하거나 원격 인증을 사용하고, 중요 서버의 펌웨어를 정기 업데이트한다.
무결성 모니터링	중요 펌웨어를 침해·무단 변조 지표 관점에서 상시 모니터링하고, 특히 BMC의 아웃바운드 트래픽을 감시하며, TPM·전용 보안칩 등 루트 오브 트러스트로 BMC 무결성 변화를 점검한다.
공급망 검증	신규 장비의 공급망을 점검하고, 모든 신규 서버가 주요 취약점 패치와 최신 펌웨어를 적용했는지 도입 시 평가한다.
사회공학 대응	인프라 엔지니어 대상 가짜 채용·벤더 사칭 시뮬레이션 훈련을 정기 실시하고, 외부 코딩 과제·의존성은 격리(샌드박스) 환경에서만 실행하는 정책을 강제한다.
거대소 특화	핫월렛 서명 서버·키 관리 호스트는 BMC 콘솔 리다이렉션을 물리적으로 비활성화하고, 콘솔 접근에 대한 별도 다중 승인(MFA + 4-eyes)을 적용한다.

8. 참고 출처

- [1] **ColorTokens**. IPMI Security Risks: The Hidden Backdoor in Servers (2026) — JungleSec/KVM 악용, 단일 포트 장악 영향. <https://colortokens.com/blogs/ipmi-security-risks-server-management-microsegmentation/>
- [2] **Eclipsium**. The iLObleed Implant: Lights Out Management — 펌웨어 임플란트 지속성. <https://eclipsium.com/blog/the-ilobleed-implant-lights-out-management-like-you-wouldnt-believe/>
- [3] **Eclipsium**. BMC&C: Lights Out Forever / Supply Chain Vulnerabilities — BMC 무결성 모니터링 권고. <https://eclipsium.com/research/bmcc-lights-out-forever/>
- [4] **Supermicro**. Vulnerabilities in Supermicro BMC Firmware, January 2026 (CVE-2025-12006/12007). https://www.supermicro.com/en/support/security/BMC_IPMI_Jan_2026
- [5] **The Hacker News**. Lazarus social engineering — PondRAT/ThemeForestRAT, C2 admin 프레임워크. <https://thehackernews.com/search/label/lazarus%20group>
- [6] **Rescana**. Lazarus Targets npm, PyPI, GitHub Developers — 개발자 생태계 공급망. <https://www.rescana.com/post/lazarus-group-targets-npm-pypi-and-github-developers-with-fake-job-recruiter-malware-campaign>
- [7] **FortiGuard**. Lazarus Threat Actor Profile (2026) — 클라우드·공급망·AI 확대. <https://www.fortiguard.com/threat-actor/5537/lazarus>
- [8] **CCN**. Lazarus Group crypto methods — Bybit(\$1.5B), KelpDAO(\$292M) 인프라 표적. <https://www.ccn.com/education/crypto/lazarus-group-crypto-scam-methods-investors-explained/>

본 보고서는 위협 인텔리전스 분석 목적의 시나리오 기반 문서이며, 방어·탐지 역량 강화를 위한 것이다. — END OF REPORT —